

API

API SECURITY RISK ANALYSIS REPORT

Target: JSONPlaceholder Public API
Assessment Type: Black-Box Security Testing

HIGH

RISK LEVEL

4

FINDINGS

6

TESTS RUN

Mapped to OWASP API Security Top 10

Industry standard security framework

PREPARED BY: KISHORE BABU R M

ORGANIZATION: Future Interns

DATE: May 03, 2026

TOOL USED: Postman Web (API Testing)

CLASSIFICATION: CONFIDENTIAL

ASSESSMENT OVERVIEW

A comprehensive black-box security assessment was conducted on the JSONPlaceholder public REST API (jsonplaceholder.typicode.com) using Postman as the primary testing tool. The assessment followed the OWASP API Security Top 10 framework to identify, classify, and document security vulnerabilities. A total of 6 test cases were executed, resulting in 4 confirmed security vulnerabilities and 2 safe controls identified.

KEY FINDINGS SNAPSHOT



VULNERABILITY SUMMARY TABLE

#	VULNERABILITY	OWASP CATEGORY	SEVERITY	STATUS
1	No Authentication Required	API2 - Broken Authentication	HIGH	VULNERABLE
2	Broken Object Level Auth	API1 - BOLA	HIGH	VULNERABLE
3	Excessive Data Exposure	API3 - Data Exposure	MEDIUM	VULNERABLE
4	No Rate Limiting	API4 - Rate Limiting	MEDIUM	VULNERABLE
5	Input Validation (/abc)	API8 - Injection	LOW	SAFE
6	XSS Input Test	API8 - Injection	LOW	SAFE

OVERALL RISK RATING: HIGH

The API exposes sensitive user data without authentication, lacks rate limiting, and allows unauthorized access to any user record. Immediate remediation required.

VULN-001 No Authentication Required API2:2023 - Broken Authentication	HIGH
TESTED URL: GET https://jsonplaceholder.typicode.com/users DESCRIPTION: The API endpoint returns a full list of all user records without requiring any authentication token, API key, or login credentials. Any anonymous user or attacker can access this data freely. IMPACT: Complete exposure of all user data including names, emails, phone numbers, physical addresses, and GPS coordinates to unauthorized parties. REMEDiation: Implement JWT (JSON Web Token) or OAuth 2.0 authentication. All endpoints must validate the Authorization header before returning any data.	
VULN-002 Broken Object Level Authorization (BOLA) API1:2023 - Broken Object Level Authorization	HIGH
TESTED URL: GET https://jsonplaceholder.typicode.com/users/2 DESCRIPTION: An attacker can access any user's data by simply changing the numeric ID in the URL. No check is performed to verify whether the requesting user has permission to access the target user's record. IMPACT: Attackers can enumerate all user IDs from 1 to N and harvest the complete user database. This is one of the most exploited API vulnerabilities in REMEDiation: Implement object-level authorization checks. Verify that the authenticated user has explicit permission to access the requested resource before	
VULN-003 Excessive Data Exposure API3:2023 - Excessive Data Exposure	MEDIUM
TESTED URL: GET https://jsonplaceholder.typicode.com/users/1 DESCRIPTION: The API response includes far more data than necessary: full street address, suite number, city, zip code, exact GPS latitude/longitude, phone number, company details, and personal website. IMPACT: Sensitive PII (Personally Identifiable Information) is exposed. GPS coordinates could enable physical tracking. Combined data enables identity theft REMEDiation: Apply response filtering — return only the minimum fields required by the client. Use Data Transfer Objects (DTOs) to control exactly what fields are	
VULN-004 Lack of Rate Limiting API4:2023 - Unrestricted Resource Consumption	MEDIUM
TESTED URL: GET https://jsonplaceholder.typicode.com/users (repeated) DESCRIPTION: The API does not enforce any rate limiting. Sending 10, 100, or 10,000 requests in rapid succession returns successful responses every time with no throttling or blocking. IMPACT: Enables automated attacks: credential stuffing, data scraping of the entire user database, and Denial of Service (DoS) attacks that could crash the REMEDiation: Implement rate limiting (e.g., max 100 requests/minute per IP). Return HTTP 429 Too Many Requests when exceeded. Use tools like AWS WAF,	

PRIORITY REMEDIATION ROADMAP

- 01

IMMEDIATE

Add JWT Authentication

Protect all endpoints with token-based auth. No data should return without a valid Bearer token.
- 02

IMMEDIATE

Fix Object Authorization

Add per-request authorization checks. Verify user identity matches requested resource ID.
- 03

SHORT TERM

Filter API Responses

Create response DTOs. Return only fields the client actually needs — never raw DB objects.
- 04

SHORT TERM

Implement Rate Limiting

Add 100 req/min limit per IP. Return HTTP 429 on breach. Log and monitor suspicious patterns.
- 05

LONG TERM

API Security Monitoring

Deploy API gateway with WAF, set up anomaly detection alerts, conduct quarterly pen tests.

CONCLUSION

This security assessment successfully identified 4 vulnerabilities across the JSONPlaceholder API using industry-standard black-box testing methodology and the OWASP API Security Top 10 framework. The findings demonstrate critical gaps in authentication, authorization, data minimization, and traffic control. Addressing these issues using the recommended remediation steps will significantly improve the API's security posture and protect user data from unauthorized access and potential breaches.

PREPARED BY:

KISHORE BABU R M

Security Intern | Future Interns | May 2026

TOOL USED:

Postman Web

JSONPlaceholder API